



Introducción

Es importante tener y conocer herramientas que nos permitan analizar los distintos sistemas operativos en la búsqueda de posibles vulnerabilidades. En esta práctica conoceremos dos, uno para Linux y otro para Windows.

Objetivos de aprendizaje

- Instalar *Lynis* en Ubuntu y ejecutarla para que detecte las vulnerabilidades del sistema. Indicar cuantos avisos nos indican y que posibles soluciones existen.
- Instalar la aplicación *CLARA* en Windows 10, ejecutarla , observar las vulnerabilidades que detecta y corregir el bloque que tenga peor resultado.

Requisitos

- Disponer de VirtualBox/VmwarePlayer en nuestro ordenador.
- Disponer de las ISOs necesarias para crear las máquinas virtuales necesarias, en este caso una Ubuntu y una Windows 10.

Documentación

- Lynis: <https://cisofy.com/lynis/>
- CLARA: <https://www.ccn-cert.cni.es/es/soluciones-seguridad/clara?format=html>



Desarrollo del ejercicio

Práctica con Lynis

Lynis es una herramienta de auditoría de código abierto. Analiza el sistema en busca de información de seguridad, información general del sistema, información de software instalada y disponible, errores de configuración, problemas de seguridad, cuentas de usuario sin contraseña, permisos de archivo incorrectos, auditoría de firewall, etc. Es decir, advierte de vulnerabilidades y de configuraciones inseguras encontradas y propone mejoras para securizar el sistema (hardening).

Arrancamos la máquina virtual y la actualizamos

```
alumno@alumno-VirtualBox: ~  
alumno@alumno-VirtualBox:~$ sudo apt update  
[sudo] contraseña para alumno:  
0% [Trabajando]  
  
alumno@alumno-VirtualBox:~$ sudo apt upgrade  
Leyendo lista de paquetes... Hecho  
Creando árbol de dependencias  
Leyendo la información de estado... Hecho  
Calculando la actualización... Hecho
```

Instalamos Lynis

```
alumno@alumno-VirtualBox:~$ sudo apt install lynis  
[sudo] contraseña para alumno:  
Leyendo lista de paquetes... Hecho  
Creando árbol de dependencias  
Leyendo la información de estado... Hecho
```

Para ejecutar la aplicación podemos hacer un escaneo rápido lynis

El parámetro `-Q` es para que no espere nuestra entrada para continuar

```
alumno@alumno-VirtualBox:~$ sudo lynis -Q  
  
[ Lynis 2.6.2 ]
```

Y vemos el resultado donde nos ofrece muchísima información. Observar las que pone peligro o inseguro en color rojo.



```
- Service Manager [ systemd ]
- Checking UEFI boot [ DESHABILITADO ]
- Checking presence GRUB2 [ ENCONTRADO ]
  - Checking for password protection [ NINGUNO ]
- Check running services (systemctl) [ HECHO ]
  Result: found 31 running services
- Check enabled services at boot (systemctl) [ HECHO ]
  Result: found 64 enabled services
- Check startup files (permissions) [ OK ]
- Running 'systemd-analyze security'
  - ModemManager.service: [ MEDIO ]
  - NetworkManager.service: [ EXPUESTO ]
  - accounts-daemon.service: [ INSEGURO ]
  - acpid.service: [ INSEGURO ]
  - alsa-state.service: [ INSEGURO ]
  - anacron.service: [ INSEGURO ]
  - apport.service: [ INSEGURO ]
  - avahi-daemon.service: [ INSEGURO ]
  - colord.service: [ EXPUESTO ]
```

Y al terminar el escaneo hace un resumen de los resultados indicando las advertencias, sugerencias y posibles soluciones.

```
Warnings (3):
-----
! Reboot of system is most likely needed [KRNL-5830]
  - Solution : reboot
    https://cisofy.com/lynis/controls/KRNL-5830/

! Found accounts without password [AUTH-9283]
  https://cisofy.com/lynis/controls/AUTH-9283/

! iptables module(s) loaded, but no rules active [FIRE-4512]
  https://cisofy.com/lynis/controls/FIRE-4512/

Suggestions (37):
-----
* Set a password on GRUB boot loader to prevent altering boot configuration (e.g. boot in single user mode without password) [BOOT-5122]
  https://cisofy.com/lynis/controls/BOOT-5122/

* Consider hardening system services [BOOT-5264]
  - Details : Run '/usr/bin/systemd-analyze security SERVICE' for each service
    https://cisofy.com/lynis/controls/BOOT-5264/

* If not required, consider explicit disabling of core dump in /etc/security/limits.conf file [KRNL-5820]
  https://cisofy.com/lynis/controls/KRNL-5820/
```

Para ver la solución a los problemas detectados debemos fijarnos en el código que muestra y buscarlos en Internet. Por ejemplo, al buscar en google AUTH-9283 nos muestra



AUTH-9283 - Contraseñas (sin contraseña establecida)

Esta información se proporciona como parte del proyecto comunitario de Lynis. Está relacionado con el control Lynis **AUTH-9283** y debe considerarse tal cual y sin garantías. Todos los consejos y comandos deben probarse antes de implementarlos en entornos de producción.

Detalles de control	
Categoría	Autenticación
Solicitud	

Descripción

Las contraseñas son la clave principal para acceder a una cuenta, servicios e información relacionados. Por lo tanto, deben protegerse mediante una contraseña segura y una caducidad de la contraseña. Esta prueba en particular encontró cuentas sin contraseña. Dependiendo de la sensibilidad de la información en esta máquina, verifique si es apropiado y de acuerdo con la política de seguridad.

Y para BOOT-5122 nos muestra la siguiente información

BOOT-5122 - Establecer la contraseña del cargador de arranque

Esta información se proporciona como parte del proyecto comunitario de Lynis. Está relacionado con el control de Lynis **BOOT-5122** y debe considerarse tal cual y sin garantías. Todos los consejos y comandos deben probarse antes de implementarlos en entornos de producción.

Detalles de control	
Categoría	Bota
Solicitud	

Descripción

De forma predeterminada, cualquier persona con acceso físico a la máquina puede cargar software alternativo u otro sistema operativo durante la fase de arranque. Configure una contraseña en grub para evitar esta posibilidad.

Cómo resolver

El cargador de arranque se inicia al comienzo del ciclo de arranque y permite al usuario seleccionar qué sistema operativo iniciar. Normalmente, se selecciona una entrada de forma predeterminada, con un temporizador de unos segundos. Cuando este temporizador expira, se selecciona esta entrada predeterminada, activa el inicio del sistema operativo relacionado.

Mientras Lynis escanea un sistema, realizará pruebas de un solo objetivo y mostrará el resultado de cada prueba realizada en la pantalla. Cada resultado de escaneo debe ser interpretado por el auditor y verificar lo que significa.

Detrás de la mayoría de las pruebas, dará como resultado [OK] o [ADVERTENCIA], donde el primero se considera un resultado esperado (bueno), el segundo inesperado. Sin embargo, tenga en cuenta que un resultado que diga "[OK]" NO siempre significa que el objetivo escaneado está configurado correctamente, es seguro (en términos de seguridad) o es una buena práctica.

Por el contrario, cada "[ADVERTENCIA]" no tiene por qué ser 'malo', ya que los sistemas (y sus requisitos) son diferentes. Sin embargo, como auditor, se le aconseja que les preste atención y compruebe qué influencia tiene la prueba en su sistema o política. Acciones que puede tomar después de recibir una advertencia:

- Solucionar el problema

Lea el archivo de registro sobre los antecedentes técnicos (a menudo contiene una sugerencia en la prueba), consulte las fuentes de Internet y la documentación sobre cuál puede ser el impacto del cambio.

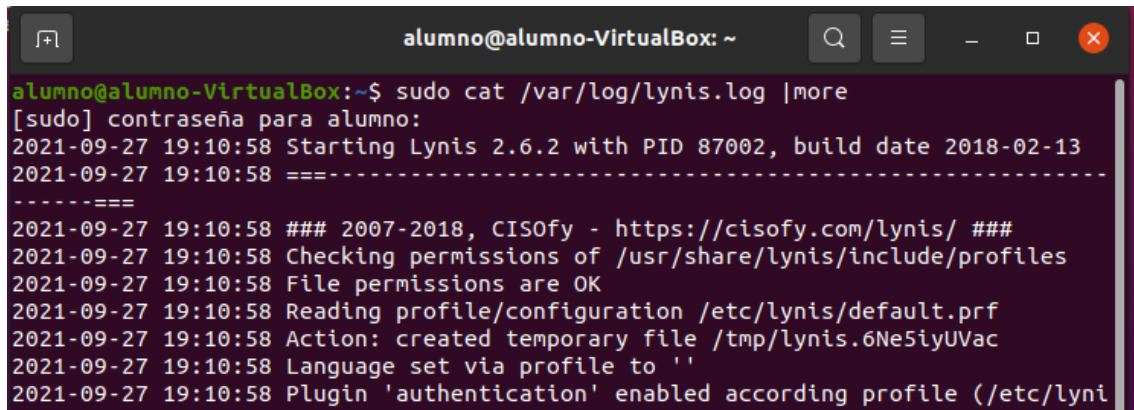
- Desactive la prueba (lista blanca)

Dentro del perfil de escaneo, las pruebas se pueden deshabilitar por completo (opción `test_skip_always`). Cuando tiene una prueba que da una advertencia y no está interesado en el resultado de esa prueba en particular, puede ignorarlo.

Registro

Cuando se analiza un sistema y se muestran los resultados, se agregará información de depuración adicional al archivo de registro (predeterminado: `/var/log/lynis.log`).

Veamos dicho archivo (nota: el parámetro `more` es para paginar la salida por pantalla)



```
alumno@alumno-VirtualBox: ~  
alumno@alumno-VirtualBox:~$ sudo cat /var/log/lynis.log | more  
[sudo] contraseña para alumno:  
2021-09-27 19:10:58 Starting Lynis 2.6.2 with PID 87002, build date 2018-02-13  
2021-09-27 19:10:58 ===-----  
-----  
2021-09-27 19:10:58 ### 2007-2018, CISofy - https://cisofy.com/lynis/ ###  
2021-09-27 19:10:58 Checking permissions of /usr/share/lynis/include/profiles  
2021-09-27 19:10:58 File permissions are OK  
2021-09-27 19:10:58 Reading profile/configuration /etc/lynis/default.prf  
2021-09-27 19:10:58 Action: created temporary file /tmp/lynis.6Ne5iyUVac  
2021-09-27 19:10:58 Language set via profile to ''  
2021-09-27 19:10:58 Plugin 'authentication' enabled according profile (/etc/lyni
```

En el archivo de registro se muestra la siguiente información:

- Hora de una acción / evento
- Razón (s) por las que una prueba falló o será omitida
- Salida de pruebas (internas) y subpruebas
- Sugerencias sobre opciones de configuración o cómo arreglar / mejorar cosas
- Amenaza / puntaje de impacto



Crear un nuevo usuario sin password y volver a ejecutar Lynis para comprobar cómo nos avisa de la vulnerabilidad.

Para crear un usuario de manera más rápida podemos utilizar el comando `useradd` que no pregunta nada y crea el usuario con todos los valores por defecto.

```
alumno@alumno-VirtualBox: ~  
alumno@alumno-VirtualBox:~$ sudo useradd usuarioprueba  
[sudo] contraseña para alumno:  
alumno@alumno-VirtualBox:~$
```

Para que el `usuarioprueba` pueda acceder al sistema sin que se le pida contraseña tecleamos el siguiente comando:

```
alumno@alumno-VirtualBox:~$ sudo passwd -d usuarioprueba  
passwd: información de caducidad de la contraseña cambiada.  
alumno@alumno-VirtualBox:~$
```

Ejecutamos Lynis y volvemos a mirar los mensajes de peligro y vemos que aparece el de cuenta sin contraseña

```
- PAM password strength tools [ SUGERENCIA ]  
- PAM configuration files (pam.conf) [ ENCONTRADO ]  
- PAM configuration files (pam.d) [ ENCONTRADO ]  
- PAM modules [ ENCONTRADO ]  
- LDAP module in PAM [ NO ENCONTRADO ]  
- Accounts without expire date [ OK ]  
- Accounts without password [ PELIGRO ]  
- Checking user password aging (minimum) [ DESACTIVADO ]  
- User password aging (maximum) [ DESACTIVADO ]  
- Checking expired passwords [ OK ]  
- Checking Linux single user mode authentication [ PELIGRO ]  
- Determining default umask  
- umask (/etc/profile) [ NO ENCONTRADO ]  
- umask (/etc/login.defs) [ SUGERENCIA ]
```

Y en el registro (`/var/log/lynis.log`) nos muestra cual es la cuenta que no tiene password

```
-----==
2021-09-27 20:26:52 Performing test ID AUTH-9283 (Checking accounts without pass
word)
2021-09-27 20:26:52 Test: Checking passwordless accounts
2021-09-27 20:26:52 Result: found one or more accounts without password
2021-09-27 20:26:52 Account without password: pepe
2021-09-27 20:26:52 Account without password: usuarioprueba
2021-09-27 20:26:52 Warning: Found accounts without password [test:AUTH-9283] [d
etails:-] [solution:-]
2021-09-27 20:26:52 ==-----
-----==
```

Otro de los avisos es que el propio lynis no está actualizado.
(Nota: si ya está actualizado a su última versión saltamos este paso)

```
=====
Lynis Actualización disponible
=====
Current version is more than 4 months old

Please update to the latest version.
New releases include additional features, bug fixes, tests, and baseline

Download the latest version:

Packages (DEB/RPM) - https://packages.cisofy.com
Website (TAR)      - https://cisofy.com/downloads/
GitHub (source)    - https://github.com/CISofy/Lynis
=====
```

Tenemos la versión 2.6.2 .

```
alumno@alumno-VirtualBox:~$ sudo lynis show version
[sudo] contraseña para alumno:
2.6.2
```

Aunque Lynis está disponible en los repositorios generales de Ubuntu puede que no estén actualizados. Para obtener la última versión hay que descargar e instalar la clave de firma PGP del repositorio de Lynis desde un servidor de claves central.

```
alumno@alumno-VirtualBox:~$ sudo wget -O - https://packages.cisofy.com/keys/cisofy-software-public.key | sudo apt-key add -
-- 2021-09-28 20:03:24 -- https://packages.cisofy.com/keys/cisofy-software-public.key
Resolviendo packages.cisofy.com (packages.cisofy.com)... 37.97.194.171, 24017c8:aac2:37b:11
Conectando con packages.cisofy.com (packages.cisofy.com)[37.97.194.171]:443... conectado.
Petición HTTP enviada, esperando respuesta... 200 OK
Longitud: 5318 (5,2K) [application/octet-stream]
Guardando como: "STDOUT"

100%[=====] 5,19K --.-KB/s en 0s

2021-09-28 20:03:25 (566 MB/s) - escritos a stdout [5318/5318]

OK
```

Instalamos el repositorio



```
alumno@alumno-VirtualBox:~$ echo "deb https://packages.cisofo.com/community/lynis/deb/ stable main" | sudo tee /etc/apt/sources.list.d/cisofo-lynis.list
deb https://packages.cisofo.com/community/lynis/deb/ stable main
```

Sincronizamos los repositorios y actualizamos

```
alumno@alumno-VirtualBox:~$ sudo apt install apt-transport-https
Leyendo lista de paquetes... Hecho
Creando árbol de dependencias
```

```
alumno@alumno-VirtualBox:~$ sudo apt update
0% [Trabajando]
```

```
alumno@alumno-VirtualBox:~$ sudo apt upgrade
Leyendo lista de paquetes... Hecho
```

Y comprobamos que ya actualizó lynis a su última versión

```
alumno@alumno-VirtualBox:~$ sudo lynis show version
3.0.6
```

Windows: Realizar la misma actividad

CLARA es una herramienta creada para analizar la seguridad técnica de los sistemas informáticos establecidas en el Real Decreto 3/2010 por el que se regula el Esquema Nacional de Seguridad. Este software ha sido diseñado para funcionar, exclusivamente, en sistemas operativos Windows, concretamente en Windows 7, Windows 10 y las versiones Server 2008 y 2012.

Podemos descargar la última versión de CLARA de forma totalmente gratuita desde el [siguiente enlace](#). Además, en él también podemos encontrar un completo manual de usuario donde nos explica todo lo que forma esta aplicación, cómo se utiliza y cómo certifica la seguridad del sistema acorde al Esquema Nacional de Seguridad.

Los resultados de los tests se guardan en formato HTML dentro de una carpeta, pudiendo acceder a ellos para conocer el nivel de seguridad de nuestro equipo y todos los fallos que hemos cometido para intentar solucionarlos.

Arrancamos la máquina virtual windows y descargamos de la página oficial la aplicación CLARA. Observar como a la izquierda hay más herramientas relacionadas con la seguridad todas con nombres de mujer. Abrir alguna de ellas al azar para ver que tipo de herramienta es. Descargamos CLARA.



ccn-cert.cni.es/soluciones-seguridad/clara.html

La notificación de incidentes, clave para la seguridad nacional.

Inicio > Soluciones > CLARA

SOLUCIONES

- ADA >
- AMPARO >
- ANA >
- ATENEA >
- CARLA >
- CARMEN >
- CCNDroid >
- CLARA >
- CLAUDIA >
- microCLAUDIA >
- ELENA >
- EMMA >
- CLORIA >
- INES >
- IRIS >
- LORETO >
- LUCIA >
- MARIA >
- MARTA >
- MONICA >
- REYES >
- PILAR >
- RODIO >
- VANESA >

CLARA

Herramienta de auditoría de cumplimiento con el ENS/GTIC en Sistemas Windows.

Herramienta para analizar las características de seguridad técnicas definidas a través del Real Decreto 3/2010 por el que se regula el Esquema Nacional de Seguridad en el ámbito de la Administración Electrónica. El análisis del cumplimiento está basado en las normas proporcionadas a través de las plantillas de seguridad de las Culas CCN-STIC 850A, 850B, 851B, 870A, 870B, 870C, 870D, 870E, 870F, 870G, 870H, 870I, 870J, 870K, 870L, 870M, 870N, 870O, 870P, 870Q, 870R, 870S, 870T, 870U, 870V, 870W, 870X, 870Y, 870Z, 870AA, 870AB, 870AC, 870AD, 870AE, 870AF, 870AG, 870AH, 870AI, 870AJ, 870AK, 870AL, 870AM, 870AN, 870AO, 870AP, 870AQ, 870AR, 870AS, 870AT, 870AU, 870AV, 870AW, 870AX, 870AY, 870AZ, 870BA, 870BB, 870BC, 870BD, 870BE, 870BF, 870BG, 870BH, 870BI, 870BJ, 870BK, 870BL, 870BM, 870BN, 870BO, 870BP, 870BQ, 870BR, 870BS, 870BT, 870BU, 870BV, 870BW, 870BX, 870BY, 870BZ, 870CA, 870CB, 870CC, 870CD, 870CE, 870CF, 870CG, 870CH, 870CI, 870CJ, 870CK, 870CL, 870CM, 870CN, 870CO, 870CP, 870CQ, 870CR, 870CS, 870CT, 870CU, 870CV, 870CW, 870CX, 870CY, 870CZ, 870DA, 870DB, 870DC, 870DD, 870DE, 870DF, 870DG, 870DH, 870DI, 870DJ, 870DK, 870DL, 870DM, 870DN, 870DO, 870DP, 870DQ, 870DR, 870DS, 870DT, 870DU, 870DV, 870DW, 870DX, 870DY, 870DZ, 870EA, 870EB, 870EC, 870ED, 870EE, 870EF, 870EG, 870EH, 870EI, 870EJ, 870EK, 870EL, 870EM, 870EN, 870EO, 870EP, 870EQ, 870ER, 870ES, 870ET, 870EU, 870EV, 870EW, 870EX, 870EY, 870EZ, 870FA, 870FB, 870FC, 870FD, 870FE, 870FF, 870FG, 870FH, 870FI, 870FJ, 870FK, 870FL, 870FM, 870FN, 870FO, 870FP, 870FQ, 870FR, 870FS, 870FT, 870FU, 870FV, 870FW, 870FX, 870FY, 870FZ, 870GA, 870GB, 870GC, 870GD, 870GE, 870GF, 870GG, 870GH, 870GI, 870GJ, 870GK, 870GL, 870GM, 870GN, 870GO, 870GP, 870GQ, 870GR, 870GS, 870GT, 870GU, 870GV, 870GW, 870GX, 870GY, 870GZ, 870HA, 870HB, 870HC, 870HD, 870HE, 870HF, 870HG, 870HH, 870HI, 870HJ, 870HK, 870HL, 870HM, 870HN, 870HO, 870HP, 870HQ, 870HR, 870HS, 870HT, 870HU, 870HV, 870HW, 870HX, 870HY, 870HZ, 870IA, 870IB, 870IC, 870ID, 870IE, 870IF, 870IG, 870IH, 870II, 870IJ, 870IK, 870IL, 870IM, 870IN, 870IO, 870IP, 870IQ, 870IR, 870IS, 870IT, 870IU, 870IV, 870IW, 870IX, 870IY, 870IZ, 870JA, 870JB, 870JC, 870JD, 870JE, 870JF, 870JG, 870JH, 870JI, 870JJ, 870JK, 870JL, 870JM, 870JN, 870JO, 870JP, 870JQ, 870JR, 870JS, 870JT, 870JU, 870JV, 870JW, 870JX, 870JY, 870JZ, 870KA, 870KB, 870KC, 870KD, 870KE, 870KF, 870KG, 870KH, 870KI, 870KJ, 870KK, 870KL, 870KM, 870KN, 870KO, 870KP, 870KQ, 870KR, 870KS, 870KT, 870KU, 870KV, 870KW, 870KX, 870KY, 870KZ, 870LA, 870LB, 870LC, 870LD, 870LE, 870LF, 870LG, 870LH, 870LI, 870LJ, 870LK, 870LL, 870LM, 870LN, 870LO, 870LP, 870LQ, 870LR, 870LS, 870LT, 870LU, 870LV, 870LW, 870LX, 870LY, 870LZ, 870MA, 870MB, 870MC, 870MD, 870ME, 870MF, 870MG, 870MH, 870MI, 870MJ, 870MK, 870ML, 870MM, 870MN, 870MO, 870MP, 870MQ, 870MR, 870MS, 870MT, 870MU, 870MV, 870MW, 870MX, 870MY, 870MZ, 870NA, 870NB, 870NC, 870ND, 870NE, 870NF, 870NG, 870NH, 870NI, 870NJ, 870NK, 870NL, 870NM, 870NN, 870NO, 870NP, 870NQ, 870NR, 870NS, 870NT, 870NU, 870NV, 870NW, 870NX, 870NY, 870NZ, 870OA, 870OB, 870OC, 870OD, 870OE, 870OF, 870OG, 870OH, 870OI, 870OJ, 870OK, 870OL, 870OM, 870ON, 870OO, 870OP, 870OQ, 870OR, 870OS, 870OT, 870OU, 870OV, 870OW, 870OX, 870OY, 870OZ, 870PA, 870PB, 870PC, 870PD, 870PE, 870PF, 870PG, 870PH, 870PI, 870PJ, 870PK, 870PL, 870PM, 870PN, 870PO, 870PP, 870PQ, 870PR, 870PS, 870PT, 870PU, 870PV, 870PW, 870PX, 870PY, 870PZ, 870QA, 870QB, 870QC, 870QD, 870QE, 870QF, 870QG, 870QH, 870QI, 870QJ, 870QK, 870QL, 870QM, 870QN, 870QO, 870QP, 870QQ, 870QR, 870QS, 870QT, 870QU, 870QV, 870QW, 870QX, 870QY, 870QZ, 870RA, 870RB, 870RC, 870RD, 870RE, 870RF, 870RG, 870RH, 870RI, 870RJ, 870RK, 870RL, 870RM, 870RN, 870RO, 870RP, 870RQ, 870RR, 870RS, 870RT, 870RU, 870RV, 870RW, 870RX, 870RY, 870RZ, 870SA, 870SB, 870SC, 870SD, 870SE, 870SF, 870SG, 870SH, 870SI, 870SJ, 870SK, 870SL, 870SM, 870SN, 870SO, 870SP, 870SQ, 870SR, 870SS, 870ST, 870SU, 870SV, 870SW, 870SX, 870SY, 870SZ, 870TA, 870TB, 870TC, 870TD, 870TE, 870TF, 870TG, 870TH, 870TI, 870TJ, 870TK, 870TL, 870TM, 870TN, 870TO, 870TP, 870TQ, 870TR, 870TS, 870TT, 870TU, 870TV, 870TW, 870TX, 870TY, 870TZ, 870UA, 870UB, 870UC, 870UD, 870UE, 870UF, 870UG, 870UH, 870UI, 870UJ, 870UK, 870UL, 870UM, 870UN, 870UO, 870UP, 870UQ, 870UR, 870US, 870UT, 870UU, 870UV, 870UW, 870UX, 870UY, 870UZ, 870VA, 870VB, 870VC, 870VD, 870VE, 870VF, 870VG, 870VH, 870VI, 870VJ, 870VK, 870VL, 870VM, 870VN, 870VO, 870VP, 870VQ, 870VR, 870VS, 870VT, 870VU, 870VV, 870VW, 870VX, 870VY, 870VZ, 870WA, 870WB, 870WC, 870WD, 870WE, 870WF, 870WG, 870WH, 870WI, 870WJ, 870WK, 870WL, 870WM, 870WN, 870WO, 870WP, 870WQ, 870WR, 870WS, 870WT, 870WU, 870WV, 870WW, 870WX, 870WY, 870WZ, 870XA, 870XB, 870XC, 870XD, 870XE, 870XF, 870XG, 870XH, 870XI, 870XJ, 870XK, 870XL, 870XM, 870XN, 870XO, 870XP, 870XQ, 870XR, 870XS, 870XT, 870XU, 870XV, 870XW, 870XX, 870XY, 870XZ, 870YA, 870YB, 870YC, 870YD, 870YE, 870YF, 870YG, 870YH, 870YI, 870YJ, 870YK, 870YL, 870YM, 870YN, 870YO, 870YP, 870YQ, 870YR, 870YS, 870YT, 870YU, 870YV, 870YW, 870YX, 870YY, 870YZ, 870ZA, 870ZB, 870ZC, 870ZD, 870ZE, 870ZF, 870ZG, 870ZH, 870ZI, 870ZJ, 870ZK, 870ZL, 870ZM, 870ZN, 870ZO, 870ZP, 870ZQ, 870ZR, 870ZS, 870ZT, 870ZU, 870ZV, 870ZW, 870ZX, 870ZY, 870ZZ

Se tiene en consideración que los ámbitos de aplicación de este tipo de plantillas son muy variados y por lo tanto dependerán de su aplicación las peculiaridades y funcionalidades de los servicios prestados por las diferentes organizaciones. Por lo tanto, las plantillas y normas de seguridad se han generado definiendo unas pautas generales de seguridad que permitan el cumplimiento de los mínimos establecidos en el ENS. No obstante, las diferentes organizaciones deberán tener en consideración el hecho de que las plantillas definidas habrán podido ser modificadas para adaptarse a sus necesidades operativas.

La aplicación se compone de CLARA ENS (versión 32 y 64 bits), para análisis independiente en entornos Microsoft Windows y CLARA ENS LINUX para entornos Linux.

La herramienta para el análisis de cumplimiento es funcional exclusivamente en sistemas Windows y Linux, tanto en sus versiones cliente como servidor, miembros de un dominio o independientes al mismo. Las versiones soportadas en esta primera versión son:

Entornos Microsoft:

- Windows 7
- Windows 10
- Windows Server 2008
- Windows Server 2008 R2
- Windows Server 2012
- Windows Server 2012 R2
- Windows Server 2016

Entornos Linux:

- CentOS 7
- CentOS 8

Descarga

CLARA ENS [Descarga] Contraseña: CLARA | Firma SHA [Descarga]

CLARA ENS Linux [Descarga] Contraseña: CLARA | Firma SHA [Descarga]

Contacto: clara@ccn-cert.cni.es

Clave PCP Descarga:

FINGERPRINT 77D3 1466 820C 8662 80CE 2072 A232 DF63 B739 3280

Nos aparece una ventana donde debemos teclear la contraseña: CLARA

File elemento compartido está protegido por contraseña

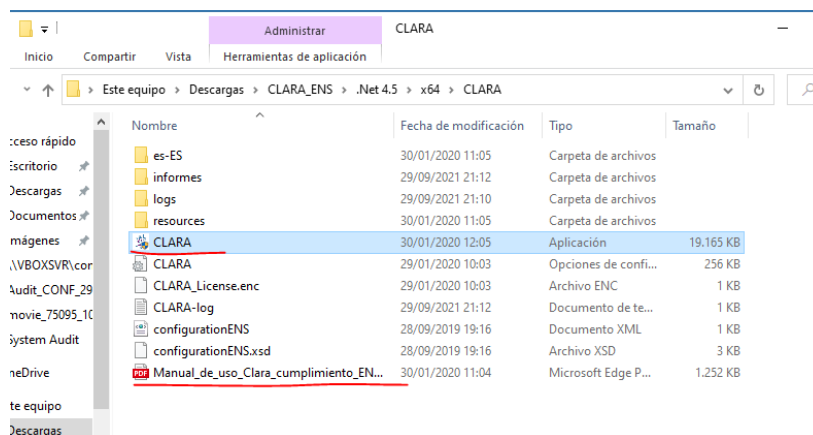
Contraseña

Proceder

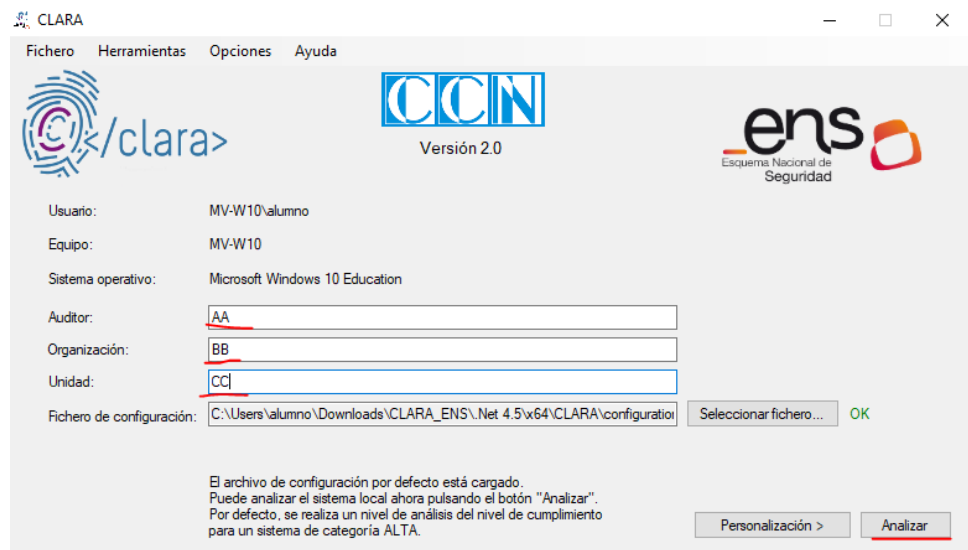
Descargamos y descomprimos el zip.



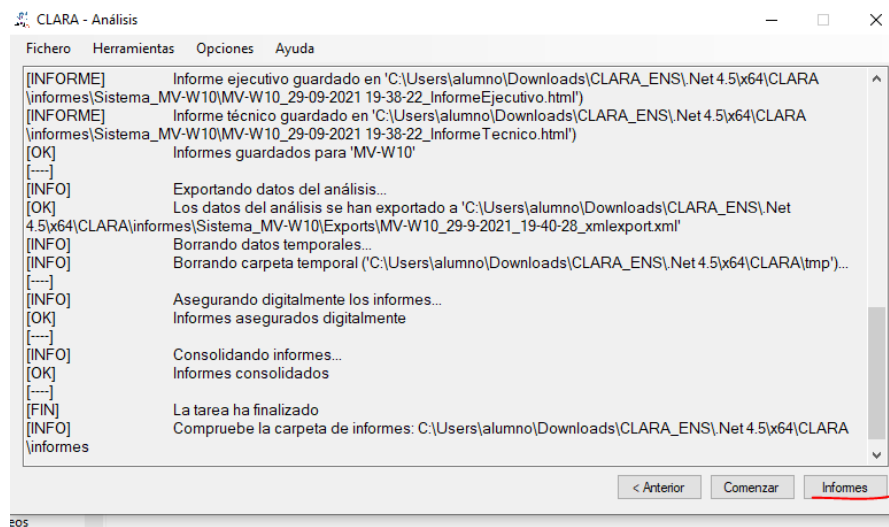
Escogemos el directorio .Net 4.0 porque es el adecuado para windows 10. Dentro de la carpeta .Net 4.0 –x64-CLARA se encuentra el Manual de uso de esta herramienta y la aplicación que ejecutamos.



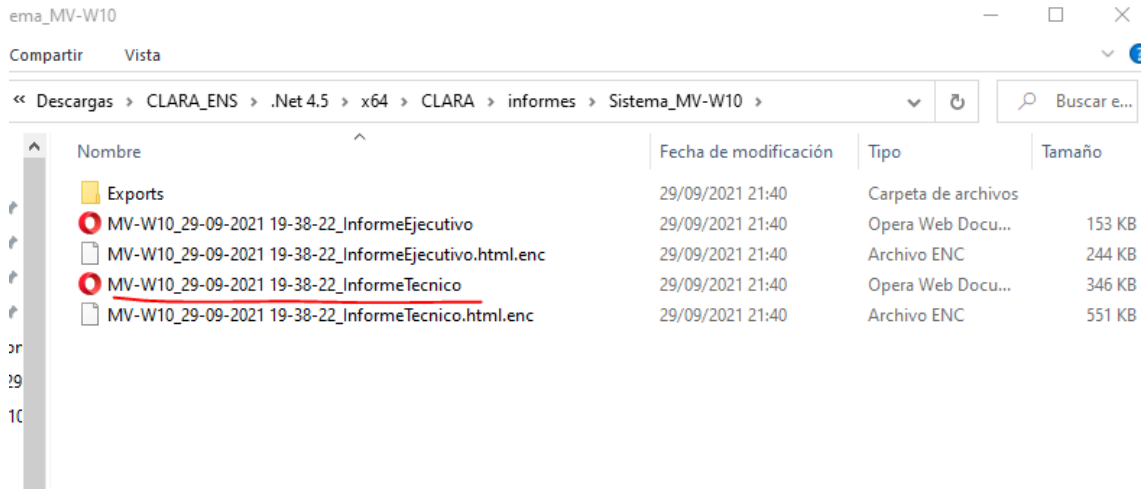
Para que empiece el análisis nos pide que llenemos los campos de Auditor, Organización y Unidad. Poner los datos que se quiera. Y pulsamos Analizar.



Una vez analizado el sistema nos muestra toda la información detallada accediendo desde el botón Informes



Y observamos los Informes técnicos que al ser formato HTML se abre en un navegador.



Observar toda la información que nos proporciona en los diferentes apartados.

Datos del sistema	Ocultar
Valor de criticidad	
Sistema	Mostrar
Discos	Mostrar
Sistema operativo	Mostrar
Configuración regional	Mostrar
Adaptadores de red	Mostrar
Análisis ENS	Ocultar
Resultados	
Valor de criticidad Cumplimiento (55,04%)	
OP.ACC.4 - Proceso de gestión de derechos de acceso (70%)	Mostrar
OP.ACC.5 - Mecanismos de autenticación (31,25%)	Mostrar
OP.ACC.6 - Acceso local (0%)	Mostrar
OP.EXP.2 - Configuración de seguridad (33,07%)	Mostrar
OP.EXP.5 - Gestión de cambios (100%)	Mostrar

Y prestar atención sobretodo a las marcadas como Incorrecto.

OP.ACC.4 - Proceso de gestión de derechos de acceso (70%)				Ocultar
Nombre	Valor actual	Valor esperado	Resultado	
Control de cuentas de usuario: comportamiento de la petición de elevación para los administradores en Modo de aprobación de administrador	Pedir consentimiento para binarios que no son de Windows	Pedir credenciales en el escritorio seguro	Incorrecto	
Control de cuentas de usuario: comportamiento de la petición de elevación para los usuarios estándar	Pedir credenciales	Pedir credenciales en el escritorio seguro	Incorrecto	
Control de cuentas de usuario: detectar instalaciones de aplicaciones y pedir confirmación de elevación	Habilitada	Habilitada	Correcto	
Control de cuentas de usuario: ejecutar todos los administradores en Modo de aprobación de administrador	Habilitada	Habilitada	Correcto	
Control de cuentas de usuario: elevar sólo aplicaciones UIAccess instaladas en ubicaciones seguras	Habilitada	Habilitada	Correcto	



El apartado bloqueo de puesto de trabajo es el que tiene el porcentaje más bajo.

MP.EQ.2 - Bloqueo de puesto de trabajo (0%)		Ocultar	
Nombre	Valor actual	Valor esperado	Resultado
Inicio de sesión interactivo: no requerir Ctrl+Alt+Supr	Habilitada	Deshabilitada	Incorrecto
Inicio de sesión interactivo: no mostrar el último nombre de usuario	Deshabilitada	Habilitada	Incorrecto
Inicio de sesión interactivo: mostrar información de usuario cuando se bloquee la sesión	No configurado	No mostrar la información del usuario	No configurado
Configuración de usuario/Panel de control/Personalización/Habilitar protector de pantalla	No configurado	Habilitada	No configurado
Configuración de usuario/Panel de control/Personalización/Proteger el protector de pantalla mediante contraseña	No configurado	Habilitada	No configurado
Configuración de usuario/Panel de control/Personalización/Tiempo de espera del protector de pantalla	No configurado	600	No configurado

Se deberá aplicar los cambios necesarios para mejorar el resultado de este apartado.

Inicio de sesión interactivo: no requerir CTRL+ALT+SUPR:

Si esta configuración de directiva está habilitada en un dispositivo, no es necesario que un usuario presione CTRL+ALT+SUPR para iniciar sesión.

Si esta directiva está deshabilitada, cualquier usuario debe presionar CTRL+ALT+SUPR antes de iniciar sesión en el sistema operativo Windows (a menos que esté usando una tarjeta inteligente para iniciar sesión). Microsoft desarrolló esta característica para facilitar a los usuarios con determinados tipos de problemas físicos iniciar sesión en el dispositivo que ejecuta Windows sistema operativo; sin embargo, no tener que presionar la combinación de teclas CTRL+ALT+SUPR hace que los usuarios puedan sufrir ataques que intenten interceptar sus contraseñas. Requerir CTRL+ALT+SUPR antes de que los usuarios inicien sesión garantiza que los usuarios se comuniquen mediante una ruta de acceso de confianza al escribir sus contraseñas.

usuario malintencionado puede instalar malware similar al cuadro de diálogo

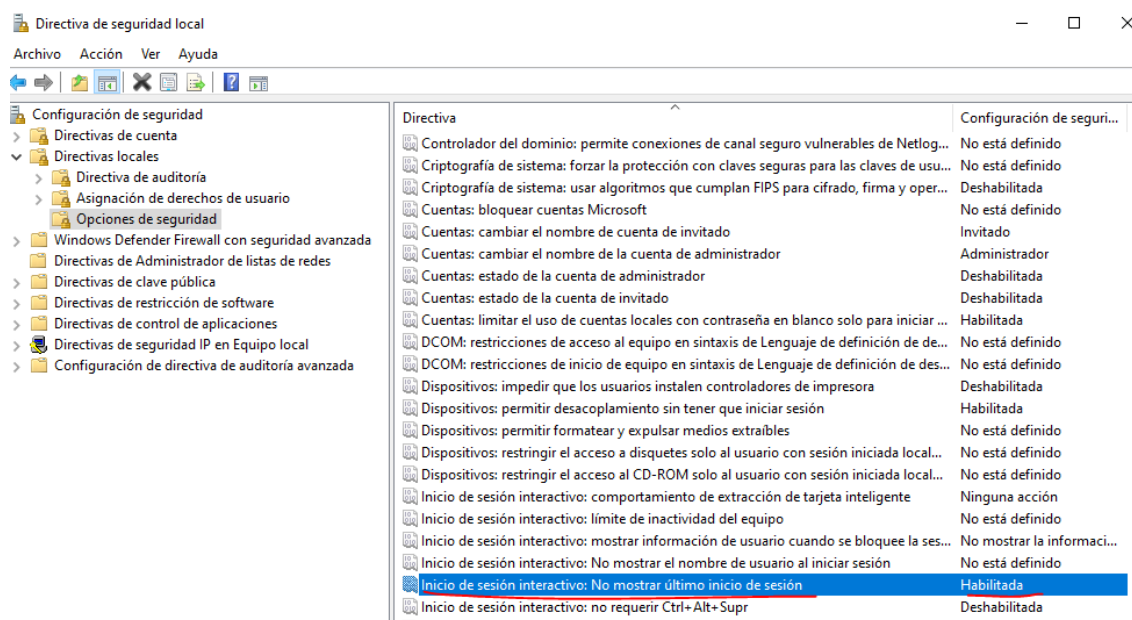


de inicio de sesión estándar para el sistema operativo Windows y capturar la contraseña de un usuario. A continuación, el atacante puede iniciar sesión en la cuenta comprometida con cualquier nivel de derechos de usuario que tenga el usuario.

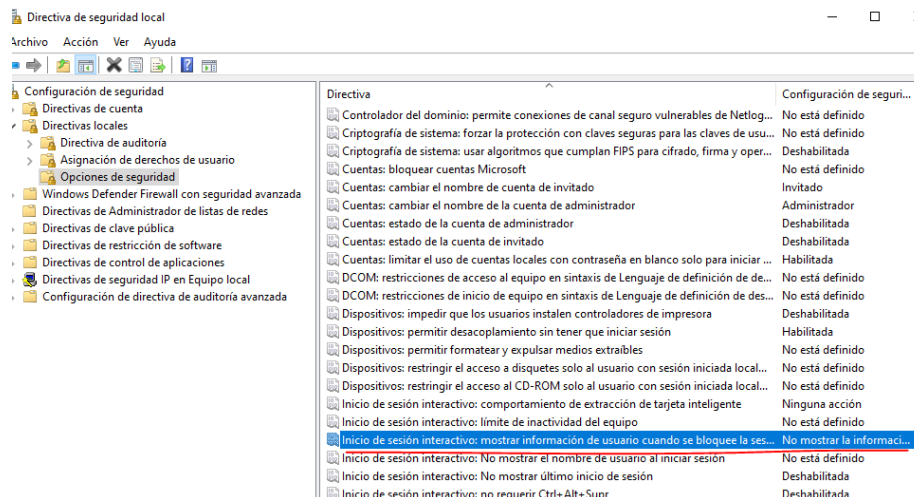
Para deshabilitarlo vamos a *Directivas locales\Opciones de seguridad*

Y la deshabilitamos haciendo doble click en ella.

Inicio de sesión interactivo: No mostrar último inicio de sesión

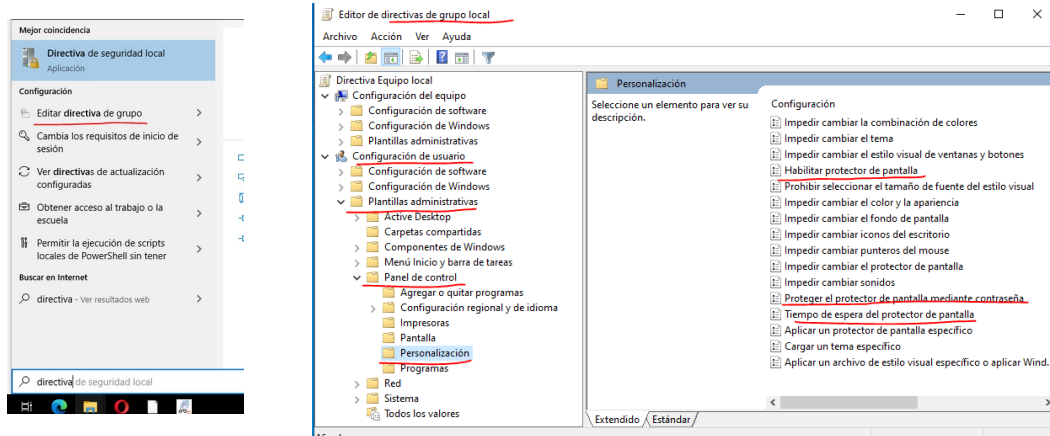


Inicio de sesión interactivo: mostrar información del usuario cuando se bloquea la sesión.
Se recomienda no mostrarla.





Configuración de usuario/Panel de control/Personalización/Habilitar protector de pantalla



Aprovechamos también para proteger protector pantalla mediante contraseña y tiempo de espera de protector de 600 segundos.

Volvemos a ejecutar CLARA para comprobar que hemos resuelto los problemas de este bloque.

MP.EQ.2 - Bloqueo de puesto de trabajo (100%)			Ocultar
Nombre	Valor actual	Valor esperado	Resultado
Inicio de sesión interactivo: no requerir Ctrl+Alt+Supr	Deshabilitada	Deshabilitada	Correcto
Inicio de sesión interactivo: no mostrar el último nombre de usuario	Habilitada	Habilitada	Correcto
Inicio de sesión interactivo: mostrar información de usuario cuando se bloquee la sesión	No mostrar la información del usuario	No mostrar la información del usuario	Correcto
Configuración de usuario/Panel de control/Personalización/Habilitar protector de pantalla	Habilitada	Habilitada	Correcto
Configuración de usuario/Panel de control/Personalización/Proteger el protector de pantalla mediante contraseña	Habilitada	Habilitada	Correcto
Configuración de usuario/Panel de control/Personalización/Tiempo de espera del protector de pantalla	600	600	Correcto

Y esa sería la forma de mejorar el sistema. Ir corrigiendo todas las posibles vulnerabilidades.